



Databricks, Inc.

**System and Organization Controls (SOC) 1
Type 2**

**Report on Management of Databricks, Inc.'s
Description of Its Data Intelligence Platform
Services System on Amazon Web Services, Microsoft
Azure, and Google Cloud Platform and on the
Suitability of the Design and Operating
Effectiveness of Controls**

**Throughout the Period
November 1, 2024 to October 31, 2025**

I.	Independent Service Auditor’s Report on a SOC 1 Examination	3
II.	Management of Databricks, Inc.’s Assertion	7
III.	Management of Databricks, Inc.’s Description of Its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform	10
IV.	Databricks, Inc.’s Description of Its Control Objectives and Related Controls, and Independent Service Auditor’s Tests of Controls and Results of Tests	27

**I. Independent Service Auditor's Report
on a SOC 1 Examination**

Independent Service Auditor's Report on a SOC 1 Examination

To the Management of
Databricks, Inc.
San Francisco, California

Scope

We have examined management of Databricks, Inc.'s (Databricks, service organization, or Company) accompanying description of its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform (the System) titled *Management of Databricks, Inc.'s Description of Its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform* for processing user entities' transactions throughout the period November 1, 2024 to October 31, 2025 (description) and the suitability of the design and operating effectiveness of controls included in the description to achieve the related control objectives stated in the description, based on the criteria identified in *Management of Databricks, Inc.'s Assertion* (assertion). The controls and control objectives included in the description are those that management of Databricks believes are likely to be relevant to user entities' internal control over financial reporting. The description does not include aspects of the System that are not likely to be relevant to user entities' internal control over financial reporting.

Databricks uses subservice organizations to provide certain services. The subservice organizations and the services provided are listed in Section III. The description includes only the control objectives and related controls of Databricks and excludes the control objectives and related controls of the subservice organizations. The description also indicates that certain control objectives specified by Databricks can be achieved only if complementary subservice organization controls assumed in the design of Databricks' controls are suitably designed and operating effectively, along with the related controls at Databricks. Our examination did not extend to controls of the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of Databricks' controls are suitably designed and operating effectively, along with related controls at the service organization. Our examination did not extend to such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

Service Organization's Responsibilities

In Section II, management of Databricks has provided an assertion about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description. Databricks is responsible for preparing the description and its assertion, including the completeness, accuracy, and method of presentation of the description and the assertion; providing the services covered by the description; specifying the control objectives and stating them in the description; identifying the risks that threaten the achievement of the control objectives; selecting the criteria stated in the assertion; and designing, implementing, and documenting controls that are



suitably designed and operating effectively to achieve the related control objectives stated in the description.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the fairness of the presentation of the description and on the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description, based on our examination.

Our examination was conducted in accordance with attestation standards established by the AICPA. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, based on the criteria in management's assertion, the description is fairly presented and the controls were suitably designed and operating effectively to achieve the related control objectives stated in the description throughout the period November 1, 2024 to October 31, 2025. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

- Performing procedures to obtain evidence about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description, based on the criteria in management's assertion.
- Assessing the risks that the description is not fairly presented and that the controls were not suitably designed or operating effectively to achieve the related control objectives stated in the description.
- Testing the operating effectiveness of those controls that management considers necessary to provide reasonable assurance that the related control objectives stated in the description were achieved.
- Evaluating the overall presentation of the description, suitability of the control objectives stated therein, and suitability of the criteria specified by the service organization in its assertion.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of user entities and their auditors who audit and report on user entities' financial statements and may not, therefore, include every aspect of the System that each individual user entity may consider important in its own particular environment. Because of their nature, controls at a service organization may not prevent, or detect and correct, all misstatements in processing or reporting transactions. Also, the projection to the future of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design or operating effectiveness of controls to achieve the related control objectives, is subject to the risk that controls at a service organization may become ineffective.



Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section IV.

Opinion

In our opinion, in all material respects, based on the criteria described in Databricks, Inc.'s assertion:

- a. The description fairly presents Databricks' Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform that was designed and implemented throughout the period November 1, 2024 to October 31, 2025.
- b. The controls related to the control objectives stated in the description were suitably designed to provide reasonable assurance that the control objectives would be achieved if the controls operated effectively throughout the period November 1, 2024 to October 31, 2025 and if the subservice organizations and user entities applied the complementary controls assumed in the design of Databricks' controls throughout the period November 1, 2024 to October 31, 2025.
- c. The controls operated effectively to provide reasonable assurance that the control objectives stated in the description were achieved throughout the period November 1, 2024 to October 31, 2025 if complementary subservice organization controls and complementary user entity controls assumed in the design of Databricks' controls operated effectively throughout the period November 1, 2024 to October 31, 2025.

Restricted Use

This report, including the description of tests of controls and results thereof in Section IV, is intended solely for the information and use of Databricks, user entities of Databricks' Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by user entities themselves, when assessing the risks of material misstatement of user entities' financial statements.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

BDO USA, P.C.

December 15, 2025

II. Management of Databricks, Inc.'s Assertion

Management of Databricks, Inc.'s Assertion

We have prepared the accompanying description of Databricks, Inc.'s (Databricks, service organization, or Company) Data Intelligence Platform Services System on Amazon Web Services (AWS), Microsoft Azure (Azure), and Google Cloud Platform (GCP) (the System) titled *Management of Databricks, Inc.'s Description of Its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform* for processing user entities' transactions throughout the period November 1, 2024 to October 31, 2025 (description) for user entities of the System during some or all of the period November 1, 2024 to October 31, 2025 and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by the subservice organizations and user entities of the System themselves, when assessing the risks of material misstatement of user entities' financial statements.

Databricks uses subservice organizations to provide certain services. The subservice organizations and the services provided are listed in Section III. The description includes only the control objectives and related controls of Databricks and excludes the control objectives and related controls of the subservice organizations. The description also indicates that certain control objectives specified by Databricks can be achieved only if complementary subservice organization controls assumed in the design of Databricks' controls are suitably designed and operating effectively, along with the related controls at Databricks. The description does not extend to controls of the subservice organizations.

The description indicates that certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of Databricks' controls are suitably designed and operating effectively, along with related controls at the service organization. The description does not extend to controls of the user entities.

We confirm, to the best of our knowledge and belief, that:

- a. The description fairly presents the Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform made available to user entities of the System during some or all of the period November 1, 2024 to October 31, 2025 for processing their transactions as it relates to controls that are likely to be relevant to user entities' internal control over financial reporting. The criteria we used in making this assertion were that the description:
 - i. Presents how the System made available to user entities of the System was designed and implemented to process relevant user entity transactions, including, if applicable:
 - (1) The types of services provided, including, as appropriate, the classes of transactions processed.
 - (2) The procedures, within both automated and manual systems, by which those services are provided, including, as appropriate, procedures by which transactions are initiated, authorized, recorded, processed, corrected as necessary, and transferred to the reports and other information prepared for user entities of the System.

- (3) The information used in the performance of the procedures, including, if applicable, related accounting records, whether electronic or manual, and supporting information involved in initiating, authorizing, recording, processing, and reporting transactions; this includes the correction of incorrect information and how information is transferred to the reports and other information prepared for user entities.
 - (4) How the System captures and addresses significant events and conditions other than transactions.
 - (5) The process used to prepare reports and other information for user entities.
 - (6) Services performed by a subservice organization, if any, including whether the inclusive method or the carve-out method has been used in relation to them.
 - (7) The specified control objectives and controls designed to achieve those objectives, including, as applicable, complementary subservice organization controls and complementary user entity controls assumed in the design of the service organization's controls.
 - (8) Other aspects of our control environment, risk assessment process, information and communications (including the related business processes), control activities, and monitoring activities that are relevant to the services provided.
 - ii. Includes relevant details of changes to the service organization's System during the period covered by the description.
 - iii. Does not omit or distort information relevant to the service organization's System, while acknowledging that the description is prepared to meet the common needs of a broad range of user entities of the System and their user auditors and may not, therefore, include every aspect of the System that each individual user entity of the System and its auditor may consider important in its own particular environment.
- b. The controls related to the control objectives stated in the description were suitably designed and operating effectively throughout the period November 1, 2024 to October 31, 2025 to achieve those control objectives if the subservice organizations and user entities applied the complementary controls assumed in the design of Databricks' controls throughout the period November 1, 2024 to October 31, 2025. The criteria we used in making this assertion were that:
 - i. The risks that threaten the achievement of the control objectives stated in the description have been identified by management of the service organization.
 - ii. The controls identified in the description would, if operating effectively, provide reasonable assurance that those risks would not prevent the control objectives stated in the description from being achieved.
 - iii. The controls were consistently applied as designed, including whether manual controls were applied by individuals who have the appropriate competence and authority.

Databricks, Inc.

December 15, 2025

III. Management of Databricks, Inc.'s Description of Its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform

Management of Databricks, Inc.'s Description of Its Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform

Overview

This is a SOC 1 Type 2 report on Databricks, Inc.'s (Databricks, service organization, or Company) Data Intelligence Platform Services System on Amazon Web Services (AWS), Microsoft Azure (Azure), and Google Cloud Platform (GCP) for processing user entities' transactions throughout the period November 1, 2024 to October 31, 2025, which may be relevant to the internal control over financial reporting of user entities. The description has been prepared in accordance with the guidance issued by the AICPA, specifically, AT-C Section 320, *Reporting on an Examination of Controls at a Service Organization Relevant to User Entities' Internal Control Over Financial Reporting*.

Databricks, Inc.'s founders started the Spark research project at UC Berkeley, which later became Apache Spark™. Databricks was founded in 2013 by the original creators of popular open-source projects, including Apache Spark, Delta Lake, MLflow, and Unity Catalog. As the world's first Data Intelligence Platform in the cloud, Databricks combines the best elements of data lakes and data warehouses to offer an open and unified platform for data, analytic, and AI.

Databricks is on a mission to simplify and democratize data and AI, helping data teams solve the world's toughest problems. As the leader in Unified Data Analytics, Databricks helps organizations make all their data ready for analytics, empower data science and data-driven decisions across the organization, and rapidly adopt machine learning to outpace the competition. It is simple, open, and supports multi-cloud. By providing data teams with the ability to process massive amounts of data in the cloud and power AI with that data, Databricks helps organizations innovate faster and tackle challenges like treating chronic disease through faster drug discovery, improving energy efficiency, and protecting financial markets. More than 10,000 organizations worldwide rely on Databricks to enable massive-scale data engineering, collaborative data science, full-lifecycle machine learning, and business analytics.

Databricks is venture-backed and headquartered in San Francisco, California with offices around the world and has over 5,000+ global partners, including Microsoft, Amazon, Google, Tableau, Informatica, Qlik, Dataiku, Fivetran, Accenture, Capgemini, and Booz Allen Hamilton.

Services Provided

Databricks provides a Data Intelligence Platform Service system for massive scale data engineering and collaborative data science in AWS, including AWS GovCloud Classic, as well as in Azure and GCP. The Databricks solution offers multitenant services that consist of a Control Plane, Compute Plane, and Customer Data Storage:

- **Control Plane** – The portion of the Data Intelligence Platform Service system that is always hosted in the Databricks-managed AWS, Azure, or GCP environment. It contains the core Databricks services such as web application, cluster management, access control to resources, and managing running or scheduled jobs. This report covers the Control Plane.

- *Compute Plane* – This is where the extensive data processing occurs (server clusters of the compute layer). The type of data processed is chosen by the customer. As of the report date, there are two types of Compute Planes.
 - *Serverless Compute Plane* – This resides in the customer’s Databricks-managed and -owned AWS, Azure, or GCP account rather than the customer-owned AWS, Azure, or GCP account. AWS, Azure, and GCP Serverless Compute Plane are in-scope and covered by this report.
 - *Classic Compute Plane* – This resides in the customer-owned AWS, Azure, or GCP account and is not covered by this report.
- *Customer Data Storage* – This is where customer datasets are stored at rest when they use Databricks services. As of the report date, for the AWS Serverless Compute model environment, customers may select from the below storage options:
 - Databricks-managed storage – AWS Simple Storage Service (S3) bucket resides in the Databricks AWS account and is covered by this report.
 - Customer-managed storage – AWS S3 bucket resides in the customer-managed AWS account and is not covered by this report.

For other environments, customers store the data in their managed cloud account (i.e., AWS S3 bucket, Azure Blob Storage, Google Cloud Storage [GCS] bucket) and are excluded from the scope of the description of this report.

Databricks services enable customers to:

- Easily and quickly access data at scale.
- Process both structured data and unstructured data.
- Ingest from nontraditional data stores.
- Reduce the batch processing time.
- Deploy production-quality machine learning and streaming applications.
- Set up, tune, and scale Apache Spark clusters for the team.
- Keep clusters resilient and up to date with the latest versions.
- Schedule, run, and debug applications in production.
- Leverage more data science to aid in decision making.
- Explore and visualize data interactively.
- Connect to business intelligence tools and build real-time dashboards.

Scope

This description addresses only Databricks’ Data Intelligence Platform Services System on AWS, Azure, and GCP provided to its user entities and excludes other services provided by Databricks. The description is intended to provide information for user entities of the System and their independent auditors who audit and report on such user entities’ financial statements, to be used

in obtaining an understanding of the System and the controls over that System that are likely to be relevant to user entities' internal control over financial reporting. The description of the System includes certain business process controls and IT general controls that support the delivery of Databricks' System. The description does not encompass all aspects of the services provided or procedures followed that are unrelated to internal control over financial reporting activities performed at Databricks.

Databricks uses subservice organizations to provide certain services. The subservice organizations and the services provided are listed in the following table. The description does not extend to the control objectives and related controls at the subservice organizations.

Subservice Organization	Services Provided
Amazon Web Services, Inc. (Amazon)	Provides managed services over infrastructure, logging, and key management services.
Microsoft Corporation (Microsoft)	Provides managed services over infrastructure, logging, monitoring, vulnerability scan, and key management services.
Google LLC (Google)	Provides managed services over infrastructure, logging, and key management services.
Okta, Inc. (Okta)	Single sign-on (SSO) and authentication services.

Internal Control Framework

This section provides information about the five interrelated components of internal control at Databricks: control environment, risk assessment process, monitoring activities, information and communications, and control activities.

Databricks' internal control components include controls that may have a pervasive effect on the organization, specific processes, account balances, disclosures, classes of transactions, or applications. Some of the components of internal control have more of an effect at the entity level, while other components are primarily related to specific processes or applications.

Control Environment

The control environment sets the tone of an organization, influencing the control awareness of the organization. The control environment is embodied by the organization's awareness of the need for controls and the emphasis given to the appropriate controls through management's actions supported by its policies, procedures, controls, and organizational structure.

Although the control objectives and related controls are presented in Section IV, *Databricks, Inc.'s Description of Its Control Objectives and Related Controls, and Independent Service Auditor's Tests of Controls and Results of Tests*, they are an integral part of Databricks' system description.

Commitment to Integrity and Ethical Values

Databricks has developed a Global Code of Conduct that addresses acceptable business practices, conflicts of interest, and expected standards of ethical and moral behavior. There is an established "tone at the top," including explicit guidance about what is right and wrong. This tone is communicated and practiced by executives and management throughout the organization. The

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

importance of strong ethics and controls is discussed with newly hired employees throughout both the interview process and orientation.

Specific control activities implemented by Databricks in this area are described below:

- Formally documented organizational policy statements and codes of conduct communicate entity values and behavioral standards to personnel.
- The Board of Directors meets at least quarterly and is consulted and involved in significant business decisions.
- Background checks are performed for employees and contractors (with an assigned corporate Databricks account) as a component of the hiring process.

Oversight Responsibilities of the Board of Directors

Executive management meets quarterly with the Board of Directors to discuss the operations of Databricks, including relevant information on internal controls and external assessments.

Separate evaluations, conducted periodically, vary in scope and frequency depending on assessment of risks, effectiveness of ongoing evaluations, and other management considerations. Findings are evaluated against criteria established by management and the Board of Directors, and deficiencies are communicated to management and the Board of Directors as appropriate. Databricks management and supervisory personnel monitor the quality of internal control performance as a routine part of their activities.

Databricks evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the Board of Directors, as appropriate. Instructions for reporting deficiencies have been developed and are provided to employees and contractors who require a corporate Databricks account.

Assignment of Authority and Responsibility

Databricks has established appropriate lines of reporting, which facilitate the flow of information to appropriate people in a timely manner. Roles and responsibilities are segregated based on functional requirements. Databricks has an organizational chart that sets forth Databricks' lines of reporting.

Management and employees are assigned appropriate levels of authority and responsibility to facilitate effective internal control.

Specific control activities the service organization has implemented in this area are described below:

- Organizational charts are in place to communicate key areas of authority and responsibility.
- Organizational charts are available to employees and updated as needed.

Commitment to Competence

Databricks management has considered the competence levels for particular jobs and translated required skills and knowledge levels into written position requirements. Candidate resumes are

evaluated against essential skills listed in the job description. If the minimum criteria are met, an interview is scheduled with the applicable manager. When the final candidate is selected, a written offer is provided.

Employees and contractors who require a corporate Databricks account are required to complete security awareness training upon hire and on an annual basis. The security awareness training covers information on relevant security best practices and includes the responsibility for employees to communicate security concerns. Various technical training and operating procedures are also recommended and made available to employees to help maintain employees' competency. Developers are required to take the secure software development training at least annually. Security Engineers, who are responsible for handling security incident responses, are required to take incident response training at least annually. Additionally, training is conducted on the job by the hiring manager. Team members are encouraged to broaden their skill sets by attending industry security conferences and other types of training.

Risk Assessment Process

Databricks has a risk assessment process to identify and manage risks that could affect Databricks' ability to provide reliable services to its clients. This process requires management to identify significant risks in its areas of responsibility and to implement appropriate measures to address those risks. In designing its controls, Databricks has considered the risks that could prevent it from effectively addressing the criteria under the security, availability, and confidentiality trust services categories. The key risks that Databricks has identified and is focused on controlling include:

- Data security
- Compliance
- Competition
- Fraud
- Reputational risk if errors or fraud occur

Risk is defined as the possibility that an event will occur and adversely affect the achievement of objectives. Risk assessment involves a dynamic and iterative process for identifying and assessing risks to the achievement of objectives. Risks to the achievement of these objectives from across the entity are considered relative to established risk tolerances. Thus, risk assessment forms the basis for determining how risks will be managed. A precondition to risk assessment is the establishment of objectives linked at different levels of the entity. Management specifies objectives within categories relating to operations, reporting, and compliance with sufficient clarity to be able to identify and analyze risks to those objectives. Management also considers the suitability of the objectives for the entity. Risk assessment also requires management to consider the impact of possible changes in the external environment and within its own business model that may render internal control ineffective.

Databricks identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed. Databricks' risk assessment process includes an analysis of possible threats and vulnerabilities relative to each of the objectives. The risk identification process includes consideration of both internal and external factors and their impact on the achievement of the objectives.

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Appropriate levels of management are involved in the risk assessment process. Identified risks are analyzed through a process that includes estimating the potential significance of the risk. Databricks' risk assessment process includes considering how the risk should be managed and whether to accept, avoid, mitigate, or share the risk.

Databricks considers the potential for fraud in assessing risks to the achievement of objectives. The assessment of fraud risk considers fraudulent reporting, possible loss of assets or data, and corruption resulting from the various ways that fraud and misconduct can occur. It also considers opportunities for unauthorized acquisition, use or disposal of assets, altering of the entity's reporting records, or committing other inappropriate acts, and how management and other personnel might engage in or justify inappropriate actions.

Databricks identifies and assesses changes that could significantly impact the system of internal control. The risk identification process considers changes to the regulatory, economic, and physical environment in which Databricks operates.

Databricks considers the potential impacts of new business lines, dramatically altered compositions of existing business lines, acquired or divested business operations, rapid growth, and new technologies on the system of internal control.

As part of the risk assessment process, Databricks determines mitigation strategies for the risks that have been identified and designs, develops, and implements controls, including policies and procedures, to implement its risk mitigation strategy.

Integration with Risk Assessment

The environment in which the System operates; the commitments, agreements, and responsibilities of Databricks' Data Intelligence Platform Services system on AWS, Azure, and GCP; as well as the nature of the components of the System, result in risks that the criteria will not be met. Databricks addresses these risks through the implementation of suitably designed controls to provide reasonable assurance that the criteria are met. Because each system and the environment in which it operates are unique, the combination of risks to meet the criteria and the controls necessary to address the risks will be unique. As part of the design and operation of the System, Databricks management identifies the specific risks that the criteria will not be met and the controls necessary to address those risks.

Monitoring Activities

Members of Databricks regularly participate in security or risk-based groups to monitor the impact of emerging technologies. Additionally, Databricks holds quarterly Security and Privacy Risk Committee meetings to discuss current projects and any potential security concerns.

Ongoing Monitoring

Ongoing evaluations, built into business processes at different levels of the entity, provide timely information. Separate evaluations, conducted periodically, vary in scope and frequency depending on assessment of risks, effectiveness of ongoing evaluations, and other management considerations. Findings are evaluated against criteria established by management and the Board of Directors, and deficiencies are communicated to management and the Board of Directors as appropriate.

Databricks management and supervisory personnel monitor the quality of internal control performance as a routine part of their activities.

Reporting Deficiencies

Databricks evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the Board of Directors, as appropriate. Instructions for reporting deficiencies have been developed and are provided to employees and to contractors who require a corporate Databricks account.

Remediation and Continuous Improvement

Areas of noncompliance in Databricks' internal control system may surface from many sources, including the Company's ongoing monitoring procedures, separate evaluations of the internal control system, and external parties. Management evaluates the specific facts and circumstances related to areas of noncompliance in internal control procedures and makes the decision for addressing any noncompliant items based on whether the incident was isolated or a change in the Company's policies, procedures, or personnel is required. Management has developed protocols to help ensure communication of findings of internal control noncompliance, if identified, is reported to control owners, process owners, and other personnel who are in the position to take corrective action.

Monitoring of Subservice Organizations

New vendors undergo a risk management process prior to engaging their services. This includes the Security Assurance team review of vendor service reports and questionnaires, where applicable. Vendors that are considered critical, including Databricks subprocessors, to the System requirements and commitments are monitored and reviewed annually to ensure that the terms and conditions of the agreements are being adhered to and that information security incidents and problems are managed properly.

Information and Communications

Internal Communication

Databricks has implemented various methods of communication designed to ensure that employees understand their individual roles and responsibilities. These methods include periodic training programs for educating employees on internal developments, industry trends, and organizational development activities. Communication is the continual, iterative process of providing, sharing, and obtaining necessary information. Internal communication is the means by which information is disseminated throughout the organization, flowing up, down, and across the entity. It enables personnel to receive a clear message from senior management that control responsibilities must be taken seriously. Employees are encouraged to communicate to their direct supervisor.

Databricks obtains or generates and uses relevant, quality information to support the functioning of internal controls. Databricks maintains data flow diagrams, flowcharts, narratives, and procedural documentation to allow easy identification of data sources, responsible personnel, and other relevant information. Databricks has methods in place to help ensure information systems maintain and produce information that is timely, current, accurate, and complete.

External Communication

External communication is twofold: it enables inbound communication of relevant external information and provides information to external parties in response to requirements and expectations.

Specific information systems used to support Databricks' Data Intelligence Platform Services system on AWS, Azure, and GCP are described in the *Services Provided* section above.

Control Objectives and Related Control Activities

The service organization has developed a variety of policies and procedures, including related control activities, to help ensure that the service organization's objectives are carried out and that risks are mitigated. These control activities help ensure that services are administered in accordance with the service organization's policies and procedures.

Control activities are performed at multiple levels throughout the organization and at various stages during the relevant business process. Controls may be preventive or detective in nature and may encompass a range of manual and automated controls, including authorizations, reconciliation, and IT controls. Duties and responsibilities are allocated among personnel to ensure that a proper segregation of duties is maintained.

Databricks has specified the control objectives and identified the controls that are designed to achieve the related control objectives below.

Although the specified control objectives and related controls are presented in Section IV, titled *Databricks, Inc.'s Description of Its Control Objectives and Related Controls, and Independent Service Auditor's Tests of Controls and Results of Tests*, they are an integral part of Databricks' system description.

Control Objective 1 – Security Organization

Controls provide reasonable assurance that information security policies relevant to user entities' internal control over financial reporting are defined, implemented, and communicated.

Databricks has put into place a set of policies and procedures designed to provide requirements and guidance for management and employees regarding security, availability, and confidentiality. Databricks reviews those policies annually and makes them available to all Databricks personnel. Teams are expected to implement procedures that define how services are delivered. Exceptions to Databricks' policies are documented, tracked, and reviewed. Databricks personnel that fail to comply with Databricks' security policies are subject to a disciplinary process.

Databricks' security policies cover, but are not limited to, the following domains:

- Anti-Malware
- Application Development
- Asset Management
- Access Control and Authentication
- Incident Response Management
- Logging and Monitoring
- Network Security
- Personal Management

- Database Backup
- Business Continuity and Disaster Recovery
- Bring Your Own Device (BYOD)
- Change Management
- Cryptography
- Data Classification and Handling
- Data Collection, Storage, and Use
- Data Retention and Destruction
- Remote Access and Teleworking
- Removable Media
- Risk Assessment
- Security Governance and Compliance
- Third Party Management
- Training and Awareness
- Vulnerability Management

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Databricks has documented security policies around logical access that include access management, data classification, acceptable use, and password management. Policy documents are available to Databricks employees through the Databricks intranet.

Access to the production environment follows the principle of least privilege and is based on business need. Access to systems is protected by authentication and authorization controls. Databricks utilizes an SSO solution with YubiKey multifactor authentication (MFA) to manage access to key systems.

Databricks follows a formal process for managing user accounts and controlling access to resources, which is designed to ensure that access is given based on their roles and the least privilege principle.

Upon notification of an employee termination, HR will initiate the termination process in Workday, which triggers an automated workflow to automatically deprovision the assigned system access of each terminated user in Okta and other systems.

On a quarterly basis, IT performs user access reviews for the in-scope production environments and systems. Appropriate action is taken for any issues identified in the review.

In addition, logical access to the AWS GovCloud environment follows the standard authentication and authorization controls, but it is restricted to employees or contractors who have been validated as a U.S. person (citizen as defined by the U.S. Department of State) on U.S. soil.

Databricks Access to Production Systems

To grant secure access to internal core production infrastructure systems, Databricks uses an authentication and authorization application called Teleport. There is only one Teleport instance that can be used for all clouds.

Only personnel in the Databricks Engineering organization who support internal infrastructure can log into Teleport and access Databricks' core production infrastructure systems. All write access requests require secondary approval. If Databricks personnel outside infrastructure support roles request access to such systems that are managed and owned by other teams, additional approvals are required. Teleport grants internal production system access through a time-limited Transport Layer Security (TLS) client certificate. The Teleport certificate has a Time to Live (TTL) of eight hours for the production and 24 hours for the nonproduction systems. After the session time expires, the request process must be repeated. All access requests are logged and monitored in Secfood and stored for at least a year.

Teleport requires users to be on the Databricks network, and MFA is required.

Access to Web Application

By default, Databricks personnel do not have access to customer workspaces. Databricks staff may request temporary access to a customer workspace in order to investigate an outage or security event or to support deployment. Genie is used to access customer workspaces/web applications. There are Genie instances for AWS, Azure, and GCP, respectively.

Databricks customer support personnel (or individuals in direct support roles such as Solution Architects) can use Genie to request HTTPS access to the web application to provide support. For customers who deploy on Azure, support personnel also include authorized Azure support personnel.

Databricks support personnel must enter the Databricks web application ID of the customer and a valid Salesforce support ticket identification number. Microsoft support personnel must enter the customer ticket ID, subscription ID, requester ID, and organization. Support personnel are required to gain and document customer consent before using Genie to access a customer workspace. If Databricks customer support personnel require additional troubleshooting, they create an internal Engineering Support Ticket for the Databricks Engineering team.

The Databricks Engineering team can log into Genie to request access to the customer's workspace in the web application for further troubleshooting or emergency support. The Databricks Engineering team follows the same process as above, except it enters the web application ID and an internal Engineering Support Ticket (not a Customer Support Ticket).

Both Databricks support personnel and engineers require a second person approval for customer workspace access. Genie grants web application access through a time-limited access token. After the session time expires, the request process must be repeated. Genie requires users to be on the Databricks network or the Microsoft internal support network (this is for the Genie Azure instance specifically), and MFA is required.

Genie Sessions

The default Genie session time for web application access is 60 minutes. However, time limits can also be set in advance to the expected duration of the support session. The maximum time for customer approved workspace login windows can last up to 24 hours.

Genie Access Logs

The Genie application logs all access requests, and the Genie logs are stored for at least a year. Additionally, the Databricks platform logs access in a way that allows auditing of Genie access events using Audit Logs. Customers can optionally receive the Audit Logs for their account in order to review the actions taken and to confirm the integrity and security of the System. For AWS customers, access to Audit Logs is part of the Premium tier and Enterprise tier. For Azure customers, access to Audit Logs requires the Premium tier. For GCP customers, access to Audit Logs is part of the Premium tier.

Customer Access to Web Application

Customers have the responsibility to manage their own Databricks application-level access and resource access using permissions that administrators may assign to individual users or groups. Databricks does not have access to user credentials.

AWS

For user login on Databricks hosted on AWS, this initial user account uses Databricks' native authentication, which is the default non-SSO user authentication. Administrators can create other admin or non-admin accounts that use Databricks native authentication, enable SSO, or synchronize user accounts with an external system.

Databricks strongly recommends that customers implement SSO to authenticate to their Databricks workspace. Traditionally, Databricks customers have been able to authenticate with a username and password if they do not wish to require usage of SSO. Beginning in mid-2024, Databricks began deprecating user passwords. If SSO is not configured, a one-time password will be sent to the user's email address.

To allow access in the event of an SSO outage or misconfiguration, configure the emergency access feature for administrators. Up to ten configured users can sign into Databricks using a password and MFA via a security key. A security key can be hardware-based, like a physical security key, or software-based, like a mobile authenticator app. Databricks recommends configuring at least one hardware key. Passwords for the administrators configured with emergency access are only stored, salted, and hashed using PBKDF2 with the HMAC SHA1 function and are not stored in plaintext.

For AWS customers, SSO users securely sign in using identity providers (IdPs) that comply with the industry-standard SAML 2.0 or OIDC protocol. Databricks supports the most popular IdPs including Okta, Google for Work, OneLogin, Ping Identity, and Azure Entra ID. Databricks also recommends that customers configure their IdP to use MFA. Databricks does not have access to the user's MFA credentials.

For REST API authentication, Databricks provides built-in revocable personal access tokens that are created through the web application user interface. Individual tokens have their own lifespan, including revocation and optional expiration dates. Databricks also supports OAuth tokens for user-to-machine and machine-to-machine authentication and recommends service principals with limited privileges for programmatic access.

Databricks also supports the System for Cross-domain Identity Management (SCIM) protocol, which is typically used in conjunction with SSO. SCIM is a standard for automating the exchange of user

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

identity information between identity domains or IT systems for automatic provisioning and deprovisioning of users. The Databricks SCIM REST APIs also allow external systems to create groups and assign group membership. Alternatively, customers can also invoke the Databricks SCIM REST API directly to manage provisioning.

Azure

Azure Databricks always uses SSO authentication using Azure Entra ID using OpenID Connect. An important security benefit of SSO is that Azure Databricks does not have access to user passwords or other secure credentials used by MFA. By default, customers can add (provision) individual users in Azure Databricks in the Admin page using their email address, but new users must be part of the Azure Entra ID account to log in.

Azure Databricks can also use REST API authentication. Azure Databricks provides built-in revocable user security tokens that are created through the web application or API. These are called personal access tokens (PATs). Tokens have their own lifespans, including revocation and optional expiration dates. Without token management, when token-based authentication is enabled, workspace users can choose to generate and use tokens that authenticate to the Databricks REST API.

Azure Databricks also supports the SCIM protocol, allowing customers to synchronize Azure Entra ID with the directory in Azure Databricks. This benefits customer security in three primary ways: (1) when they remove a user, the user is automatically removed from Azure Databricks; (2) users can be disabled temporarily via SCIM, often used for soft lockouts or for investigations; and (3) groups and roles are automatically synchronized.

Google Cloud Platform

Databricks workspace users authenticate with their Google Cloud Identity account (or Google Workspace account) using Google's OAuth 2.0 implementation, which conforms to the OpenID Connect spec and is OpenID-certified. Databricks provides the OpenID profile scope values in the authentication request to Google. Optionally, customers can configure their Google Cloud Identity account (or Google Workspace account) to federate with an external SAML 2.0 IdP to verify user credentials. Google Cloud Identity can federate with Azure Entra ID, Okta, Ping, and other IdPs. However, Databricks only directly interacts with the Google Identity Platform APIs. There are two pathways for a workspace user to log into a workspace:

- All users can use the workspace URL directly.
 - Both non-admin users and admin users (account owners) can use the workspace URL directly. The user authenticates to the Databricks control plane through its integration with Google Cloud Identity OAuth 2.0 implementation.
- Admin users (account owners) can additionally use the Google Cloud console to access the workspace.
 - Admin users (account owners) authenticate with Google Identity OAuth 2.0 in the Account Console. The Account Console offers a list of available workspaces to choose from. The user is redirected to the workspace login page with an authentication token. If the token is accepted, the user is not prompted to log in again. On the first login, the user will be challenged to consent to OAuth scopes.

Customers can optionally use the REST APIs for SCIM, which is typically used in conjunction with SSO. SCIM is a standard for automating the exchange of user identity information between identity domains or IT systems for automatic provisioning and deprovisioning of users. The Databricks SCIM REST APIs also allow external systems to create groups and assign group membership. If the customer configures Google Cloud Identity to federate with an external IdP, that IdP may have built-in SCIM integrations. Customers can also invoke the Databricks SCIM REST API directly to manage user and group provisioning.

More information can be found in Databricks' product documentation.

Control Objective 3 – Change Management

Controls provide reasonable assurance that changes to application programs and related infrastructure and data management systems are authorized, tested, documented, approved, and implemented to result in the complete, accurate, and timely processing and reporting of transactions and balances relevant to user entities' internal control over financial reporting.

Methodology

Engineering at Databricks follows an Agile development methodology using a continuous integration and continuous deployment process. Changes to customer-impacting services are tracked, reviewed, tested, and approved.

Release Management

There are two types of releases: Databricks Control Plane release (changes made to the Control Plane) and Databricks Runtime release (changes made to the Compute Plane). Databricks releases for the multitenant environments are deployed through independent release pipelines that are managed by the corresponding Service teams – for example, webapp service team, API proxy service team, job service team, etc. Service teams are responsible for their own releases and release processes. Release cadence could be every two weeks or more frequent depending on each service team's needs. Changes are typically pushed into production in a phased deployment to limit the blast radius of any outages starting with the lowest impact sites.

Code versioning software, GitHub, is used to track and provide control over changes to source code. The software allows development personnel to check out code and modify it locally on their computer to ensure the production code will not be affected during the development process. Each piece of code that is checked back in is assigned a different version number which allows users to roll back to previous versions if changes impair system operations. The ability to modify source code within the versioning software is restricted to authorized personnel. Development and testing environments are logically separated from production, and customer data is not used for testing purposes unless authorized by the customer. The ability to promote changes in the production environment is restricted to each service team.

Pull requests have supporting engineering tickets or design documents based on the size of the change. Once a pull request is ready, a peer review is performed, and review comments are addressed, the pull request must be approved by a functional owner for that area. Approval is documented in GitHub and automatically validated.

A continuous delivery platform, Spinnaker, is used to orchestrate the continuous delivery pipelines. Jenkins/Deployment Service is used to execute jobs that would conduct the deployment.

Customer-facing feature changes are published as release notes on Databricks websites and available to all customers.

Control Objective 4 – Incident Management

Controls provide reasonable assurance that production incidents relevant to user entities' internal control over financial reporting are identified, analyzed, and responded to in accordance with documented procedures for timely resolution.

Databricks has implemented incident response procedures that are designed to efficiently and effectively manage unexpected incidents impacting the business. Databricks utilizes an incident response platform and a ticketing system to assign tasks and track incidents to resolution. When an event related to security, availability, or confidentiality is reported or detected, operations personnel examine the issue, create a security incident ticket when needed, and investigate the issue. If the outcome of the investigation is not a false positive, operations personnel will assign the event a severity score and may involve necessary individuals from other teams to resolve the issue. All Sev0 incidents require a mandatory and extended postmortem. The postmortem focuses on the correctness of the root cause(s) assessment, systemic problems that led to the root cause(s), process improvement for incident handling, and post-incident review.

Security incident management policies are communicated to employees, and incident response capabilities are tested on at least an annual basis.

Control Objective 5 – Data Backup and Replication

Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up and replicated to an alternate infrastructure securely.

Databricks leverages the database backup and recovery services of the cloud service provider. The database backups are scheduled and performed automatically daily. The backups are stored in AWS, Azure, or GCP with access restricted to authorized employees. Backup and restoration procedures are tested at least annually.

For customer-managed storage, the customer is responsible for backing up, securing access to, and encrypting customer data in the AWS S3 bucket, Azure Blob Storage, or GCS bucket for their account. Databricks is not responsible for backups of this data or any other customer data for customer-managed storage. Databricks provides customers with the ability to back up and restore their notebook data within the Databricks Control Plane so that they can selectively restore data.

Automated database backup systems are in place to perform scheduled replication of production data and systems at predefined intervals.

Complementary Subservice Organization Controls

In some instances, a service organization's controls cannot provide reasonable assurance that its control objectives were achieved without the subservice organizations performing certain activities in a defined manner. Such activities are referred to as complementary subservice organization

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

controls (CSOCs). The following CSOCs are those controls that Databricks' management assumed, in the design of the System, would be implemented by a subservice organization and are necessary, in combination with controls at Databricks, to provide reasonable assurance that the service organization's control objectives are achieved.

Number	CSOC	Applicable Control Objective
Amazon Web Services, Inc., Microsoft Corporation, Google LLC, and Okta, Inc.		
1.	The entity implements logical access policies, security software, infrastructure, and architectures over protected information assets to protect them from unauthorized access and security events.	CO2
2.	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	CO2
3.	Access to encryption keys and recovery key materials is appropriately restricted.	CO2
4.	Changes (including emergency/nonroutine) to production infrastructure and applications are recorded, authorized, tested, and approved prior to migration.	CO3
5.	External and internal security vulnerability assessment and penetration testing is performed on an annual basis.	CO4
6.	Procedures for evaluating security events and managing security incidents are implemented. Security incidents are communicated as appropriate.	CO4
Microsoft Corporation and Google LLC		
7.	Databases are encrypted, securely backed up, and stored in separate data center facilities.	CO5
Microsoft Corporation		
8.	The environment is continuously monitored for security-related events.	CO4

Complementary User Entity Controls

In some instances, a service organization's controls cannot provide reasonable assurance that its control objectives were achieved without user entities performing certain activities in a defined manner. Such activities are referred to as complementary user entity controls (CUECs). The following CUECs are those controls that Databricks' management assumed, in the design of the System, would be implemented by user entities and are necessary, in combination with controls at Databricks, to provide reasonable assurance that the service organization's control objectives are achieved.

Number	CUEC	Applicable Control Objective
1.	Customers are responsible for managing their organization's instance(s) of the Data Intelligence Platform through any customized security solutions or automated processes using setup features, application development tools, and API integration tools.	CO2
2.	Customers are responsible for ensuring that authorized users are appointed as organizational administrators, and the authorized users should follow a defined logical access management process to manage and protect the admin account user credentials to administer the Data Intelligence Platform, where applicable. Customers are responsible for appropriately managing user access to the Data Intelligence Platform and customer managed AWS, Azure, or GCP account(s).	CO2
3.	Customers are responsible for data classification and the implementation of encryption features available where deemed necessary by customer-defined requirements. Additionally, customers are responsible for their choices of libraries to prevent the inadvertent transmission of sensitive data (including PHI) over the wire in an unencrypted fashion.	CO2
4.	Customers are responsible for securing and protecting account credentials and security tokens for REST API access.	CO2
5.	Where applicable, customers are responsible for authorizing temporary access to customer support personnel from Databricks or Microsoft Azure (e.g., for technical support and troubleshooting).	CO2
6.	Customers are responsible for notifying Databricks of any unauthorized use of any password or account, or any other known or suspected breach of security, related to the use of the Data Intelligence Platform.	CO4
7.	Customers are responsible for communicating issues and incidents related to security, availability, and confidentiality to the support personnel (Databricks and Microsoft Azure, as appropriate) through identified channels.	CO4
8.	For customer-managed storage, customers are responsible for backing up, securing access to, and encrypting customer data in the AWS S3 bucket, Azure Blob storage, or GCS bucket.	CO5

**IV. Databricks, Inc.'s Description of Its Control Objectives and
Related Controls, and Independent Service Auditor's
Tests of Controls and Results of Tests**

Databricks, Inc.’s Description of Its Control Objectives and Related Controls, and Independent Service Auditor’s Tests of Controls and Results of Tests

This report, when combined with an understanding of the controls at user entities, is intended to assist auditors in planning the audit of user entities’ financial statements or user entities’ internal control over financial reporting and in assessing control risk for assertions in user entities’ financial statements that may be affected by controls at Databricks. The examination was performed in accordance with attestation standards established by the AICPA, specifically, AT-C Section 320, *Reporting on an Examination of Controls at a Service Organization Relevant to User Entities’ Internal Control Over Financial Reporting*.

Our examination was limited to the control objectives and related controls specified by Databricks in Section IV of this report and did not encompass all aspects of the services provided or controls of Databricks or extend to controls performed by subservice organizations and/or user entities. Unique processes or control situations not included in the description are outside the scope of this examination.

It is the responsibility of each user entity and its independent auditor to evaluate this information in conjunction with the evaluation of internal control over financial reporting at the user entity in order to assess the total internal control. If internal control is not effective at user entities, Databricks’ controls may not compensate for such weaknesses.

The scope of the examination included tests of the operating effectiveness of controls over Databricks’ Data Intelligence Platform Services System on AWS, Azure, and GCP and may have included tests related to the functioning of or calculations performed by the software used in the delivery of the services and of the key reports listed in Section III, but did not include any other reports except those listed in Section III.

Databricks’ internal control represents the collective effect of various factors on establishing or enhancing the effectiveness of the controls specified by Databricks. In planning the nature, timing, and extent of our testing of the controls to achieve the control objectives specified by Databricks, we considered aspects of Databricks’ control environment, risk assessment process, monitoring activities, and information and communications.

Tests of Controls

Our testing of controls was restricted to the controls specified by Databricks and was not extended to controls performed by user entities or other controls that were not documented as tested under each control objective listed in this section of the report.

The description of tests of controls and results of those tests are presented in this section of the report and are the responsibility of BDO USA, P.C., the service auditor. The description of the control objectives, the related controls, and the complementary subservice organization controls and complementary user entity controls to achieve the objectives have been specified by, and are the responsibility of, Databricks.

The basis for all tests of operating effectiveness includes inquiry of the individual(s) responsible for the control. As part of our testing of each control, we inquired of the individual(s) to determine the

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.’s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities’ financial statements or internal control over financial reporting and have a sufficient understanding of it.

fairness of the description of the control and to evaluate the design and implementation of the control. As part of our inquiries, we also gained an understanding of the knowledge and experience of the personnel managing the control(s) and corroborated evidence obtained as part of other testing procedures. While inquiries were performed for every control, our inquiries were not listed individually for every control activity tested and shown in Section IV.

Testing of the control activities may have been performed using the following methods:

Method	Description
Inquiry	Inquired of appropriate personnel and corroborated responses with management.
Observation	Observed the application, performance, or existence of the specific control(s), as represented by management.
Inspection	Inspected documents and records indicating performance of the control.
Reperformance	Reperformed the control or processing application to ensure the accuracy of its operation.

When using information produced by the service organization, we evaluated whether the information was sufficiently reliable for our purposes by obtaining evidence about the accuracy and completeness of such information and evaluating whether the information was sufficiently precise and detailed for our purposes.

Control Objective 1 – Security Organization

Controls provide reasonable assurance that information security policies relevant to user entities' internal control over financial reporting are defined, implemented, and communicated.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
1.1	Security policies and procedures are documented, communicated, made available on the internal network to appropriate personnel, and versions are maintained.	Inspected the internal Databricks network and the security policies and procedures to determine whether they are formally documented, maintained, and made available to Databricks personnel.	No exceptions noted.
		Inspected the annual security policy certification to determine whether the security policy has been communicated as part of the annual security training.	No exceptions noted.
1.2	All contractors with Databricks accounts and employees are required to review and acknowledge the security program policy and acceptable use policy upon hire and at least once per year.	Inspected the security and privacy training course material and certifications for a selection of new hires and contractors to determine whether the security program policy and the acceptable use policy were acknowledged within the training upon hire.	No exceptions noted.
		Inspected the security and privacy training course material and certifications for a selection of employees and contractors to determine whether the security policy and the acceptable use policy were acknowledged at least once per year.	No exceptions noted.
1.3	An individual is assigned as CSO with the mission and resources to centrally manage, coordinate, develop, implement, and maintain an enterprise-wide security program.	Inspected the organizational chart and the security policy to determine whether the CSO is responsible for the enterprise-wide security program.	No exceptions noted.

Control Objective 1 – Security Organization

Controls provide reasonable assurance that information security policies relevant to user entities' internal control over financial reporting are defined, implemented, and communicated.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
1.4	Security roles and responsibilities are defined in security policies.	Inspected various information security policies, including the Information Security Management System Policy and the Security Program Policy, to determine whether security roles and responsibilities have been established and documented.	No exceptions noted.
1.5	Security policies and procedures are reviewed and approved at least annually or if significant changes occur.	Inspected the DocuSign approval by the CSO to determine whether security policies and procedures have been reviewed and approved within the last year.	No exceptions noted.

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.1	New hire access is granted through a formal provisioning process.	Inspected the birthright access group rules and new employee access permissions for a selection of new employees to determine whether access is granted based on role and team.	No exceptions noted.
2.2	User access to production systems is authorized by role or approver before temporary credentials with a predefined expiration period are granted to access the Databricks web application and production servers in order to provide customer support.	Inspected the Genie and Teleport confluence page to determine whether temporary credentials with a predefined expiration period are granted to authorized users for accessing the Databricks web application and production servers in order to provide customer support.	No exceptions noted.
		Observed an authorized user request access to the Databricks web application and production server using the Genie and Teleport application to determine whether the request is routed for approval prior to access being granted.	No exceptions noted.
2.3	User access reviews are performed at least quarterly and appropriate action is taken.	Inspected the Databricks user access review for a selection of quarters and associated access removal tickets to determine whether the access review was conducted and inappropriate access was corrected.	No exceptions noted.
2.4	User access is revoked within 24 hours after termination of employment or contract.	Inspected access termination documentation for a selection of separated employees and contractors to determine whether access was removed within 24 hours.	No exceptions noted.

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.5	Administrative access to code libraries is limited to authorized users.	Inspected the system-generated list of users who have administrative access to code libraries, the users' associated job titles, and inquired of management to determine whether access is limited to authorized users.	No exceptions noted.
2.6	Access to cloud data center administration platforms is limited to authorized users.	Inspected the system-generated list of administrators to the cloud service data center provider administration platforms, administrators' associated job titles, and inquired of management to determine whether access is limited to authorized users.	No exceptions noted.
2.7	Access to authentication infrastructure is limited to authorized users.	Inspected the system-generated list of users who have access to the authentication infrastructure, inspected the users' job titles, and inquired of management to determine whether access is limited to authorized users.	No exceptions noted.
2.8	Access to administer office network infrastructure is limited to authorized users.	Inspected the system-generated list of administrators for the office network infrastructure, Prisma Access GlobalProtect VPN, the administrators' associated job titles, and inquired of management to determine whether access is limited to authorized users.	No exceptions noted.

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.9	Access to production servers is limited to authorized users.	Inspected the system-generated list of users with access to the production servers, the users' associated job titles, and inquired of management to determine whether their access is appropriate.	No exceptions noted.
2.10	The application code, system design, and the platform architecture isolate processing of different tenant requests in their own context and prevent users from accessing data of other customers.	Inspected the configuration for multitenant databases to determine whether the System is designed to prevent users from accessing data of other customers.	No exceptions noted.
2.11	Remote access to the network and internal production systems is restricted through an encrypted virtual private network (VPN) solution.	Inspected the VPN configuration and observed a user remotely access the VPN to determine whether remote access to the Databricks network and internal production environments is restricted through an encrypted VPN solution.	No exceptions noted.
		Observed a user attempt to access the Databricks network and internal production environments without the VPN to determine whether the user was denied access.	No exceptions noted.
2.12	Always-on VPN is enforced on all Databricks managed laptops to ensure secure and continuous all- remote and corporate network access.	Inspected the VPN configuration for Databricks to determine whether the VPN is configured to automatically reconnect if the VPN connection is terminated	No exceptions noted.

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.13	Access to networks and production systems requires multi-factor authentication.	Inspected the MFA configuration to determine whether access to Databricks' networks and production systems requires MFA.	No exceptions noted.
		Observed a user authenticate to the network and production environments to determine whether MFA is required to gain access.	No exceptions noted.
2.14	Production systems are configured to log security events, including the actions of privileged users.	Inspected the AWS, Azure, and GCP server build configurations and security event logs for selected systems to determine whether they were configured to enable logging, including the actions of privileged users.	No exceptions noted.
2.15	Authentication infrastructure enforces passwords for workstations and SSO applications that comply with Databricks policy for password expiration, length, complexity, and history.	Inspected the workstation and SSO password configuration settings to determine whether they are configured according to the password requirements established in the security policy.	No exceptions noted.
2.16	Vendor-supplied default passwords are required to be changed as part of the installation process.	Inspected the Databricks Password Policy to determine whether requirements to change vendor-supplied default passwords as part of the installation process is defined.	No exceptions noted.
2.17	Users, and processes acting on behalf of users, are uniquely identified.	Inspected a system-generated list of all users including service and system accounts to determine whether all accounts were uniquely identified.	No exceptions noted.

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Control Objective 2 – Logical Security

Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Reperformed an attempt to create a username that already exists in the System to determine whether the username was rejected.	No exceptions noted.
2.18	A policy exists that establishes access management and authentication requirements.	Inspected the Access Control and Authentication Policy to determine whether a policy exists that establishes access management and authentication requirements.	No exceptions noted.

Control Objective 3 – Change Management

Controls provide reasonable assurance that changes to application programs and related infrastructure and data management systems are authorized, tested, documented, approved, and implemented to result in the complete, accurate, and timely processing and reporting of transactions and balances relevant to user entities' internal control over financial reporting.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
3.1	A policy exists that establishes change management requirements.	Inspected the Change Management Policy to determine whether the policy establishes change management requirements.	No exceptions noted.
3.2	Changes to production systems are documented, tracked, tested, and authorized prior to implementation.	Inspected the pull request logs for a selection of changes to production systems to determine whether changes were documented, tracked, tested, and authorized prior to implementation.	No exceptions noted.
3.3	The ability to promote code to the production environment is limited to authorized individuals based on job roles and responsibilities.	Inspected the code merge approval configuration, system-generated list of users who have the ability to promote code to the production environment, and the users' associated job titles, and inquired of management, to determine whether access was limited to authorized users and requires an independent approval prior to code promotion.	No exceptions noted.
3.4	Development and test environments are separated from production environments to reduce the following: • The risks of unauthorized access. • Changes to the operational environment. • Impact to production systems.	Inspected AWS, Azure, and GCP environments to determine whether development and test environments are separated from the production environments.	No exceptions noted.

Control Objective 3 – Change Management

Controls provide reasonable assurance that changes to application programs and related infrastructure and data management systems are authorized, tested, documented, approved, and implemented to result in the complete, accurate, and timely processing and reporting of transactions and balances relevant to user entities' internal control over financial reporting.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
3.5	Security testing is performed during development, before features are moved to production.	Inspected the testing results for a selection of releases to determine whether security testing was performed during development, before features are moved to production.	No exceptions noted.
3.6	Test data, not production customer data, is created and used in development and test environments.	Observed the development and test environments and inquired of management to determine whether synthetic test data is generated for use.	No exceptions noted.

Control Objective 4 – Incident Management

Controls provide reasonable assurance that production incidents relevant to user entities' internal control over financial reporting are identified, analyzed, and responded to in accordance with documented procedures for timely resolution.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
4.1	A policy and procedure exist that establishes security incident response requirements.	Inspected the Security Incident Management Policy and Procedure to determine whether security incident response requirements are established.	No exceptions noted.
4.2	A policy exists that establishes logging and monitoring requirements.	Inspected the Logging and Monitoring Policy to determine whether requirements have been established and are documented.	No exceptions noted.
4.3	The Databricks Secfood application is used as a SIEM tool to support the centralized collection of key security related event logs and near real-time analysis and escalation of events.	Inspected the SIEM tool to determine whether it is configured to support the centralized collection of key security-related event logs.	No exceptions noted.
		Inspected event tickets for a selection of security-related events to determine whether events were escalated and resolved.	No exceptions noted.
4.4	Production systems are configured to log security events, including the actions of privileged users.	Inspected the AWS, Azure, and GCP server build configurations and security event logs for selected systems to determine whether they were configured to enable logging, including the actions of privileged users.	No exceptions noted.
4.5	Databricks usage of cloud service data center provider administration platforms is configured to log audit events, including the actions of privileged users.	Inspected the logging configuration and events log for AWS, Azure, and GCP to determine whether they are configured to log audit events, including the actions of privileged users.	No exceptions noted.

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Control Objective 4 – Incident Management

Controls provide reasonable assurance that production incidents relevant to user entities' internal control over financial reporting are identified, analyzed, and responded to in accordance with documented procedures for timely resolution.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
4.6	A process is in place to detect rogue wireless networks if an unauthorized access point is connected to the corporate network.	Inspected the alert configuration to determine whether there is a process in place to detect rogue wireless networks if an unauthorized access point is connected to the corporate network.	No exceptions noted.
4.7	A network intrusion detection system (IDS) is used to monitor, detect, and alert on intrusions into the network.	Inspected the IDS configuration to determine whether it is configured to monitor, detect, and alert on intrusions into the network.	No exceptions noted.
4.8	Security and privacy incidents are documented, tracked, and a root-cause analysis is performed.	Inspected the monitoring dashboard, inquired of management, and determined that no security or privacy incidents occurred during the examination period.	The circumstances that warrant the operation of this control did not occur, as there were no security or privacy incidents during the examination period, and as a result, this control could not be tested.
4.9	Applicable security and privacy incidents are reported to internal stakeholders, affected clients, third parties, and regulatory authorities.	Inspected the Databricks Security Incident Management Procedure to determine whether Databricks has a procedure for reporting applicable security and privacy incidents to internal stakeholders, affected clients, third parties, and regulatory authorities.	No exceptions noted.

Control Objective 4 – Incident Management

Controls provide reasonable assurance that production incidents relevant to user entities' internal control over financial reporting are identified, analyzed, and responded to in accordance with documented procedures for timely resolution.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the monitoring dashboard, inquired of management, and determined there were no security or privacy incidents during the examination period.	The circumstances that warrant the operation of this component of the control did not occur, as there were no security or privacy incidents during the examination period, and as a result, this component of the control could not be tested.
4.10	Security incident response capabilities are tested at least annually.	Inspected the incident response plan and test results to determine whether capabilities are tested at least annually.	No exceptions noted.
4.11	Personnel are assigned for addressing and coordinating security incident response operations.	Inspected the security incident management procedure to determine whether personnel are assigned for addressing and coordinating security incident response operations.	No exceptions noted.
		Inspected the monitoring dashboard, inquired of management, and determined no security incidents occurred during the examination period.	The circumstances that warrant the operation of this component of the control did not occur, as there were no security or privacy incidents during the examination period, and as a result, this component of the control could not be tested.

Solely for the information and use of Databricks, Inc., user entities of Databricks, Inc.'s Data Intelligence Platform Services System on Amazon Web Services, Microsoft Azure, and Google Cloud Platform during some or all of the period November 1, 2024 to October 31, 2025, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Control Objective 4 – Incident Management

Controls provide reasonable assurance that production incidents relevant to user entities' internal control over financial reporting are identified, analyzed, and responded to in accordance with documented procedures for timely resolution.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
4.12	Contacts with applicable regulatory and law enforcement agencies are identified and documented.	Inspected the security incident management procedure and the Contact with Authorities SOP to determine whether contacts with applicable regulatory and law enforcement agencies are identified and documented.	No exceptions noted.
4.13	An externally facing customer support system allows customers to report information on failures, issues, incidents, and other concerns.	Inspected the public Databricks website to determine whether an externally facing customer support system is established to allow customers to report information on failures, issues, incidents, and other concerns.	No exceptions noted.
4.14	Information on how to report potential security incidents is made available to personnel.	Inspected the Databricks intranet and Incident Response documents to determine whether information on how to report potential security incidents is made available.	No exceptions noted.
4.15	System capacity and performance are monitored 24/7/365 by Engineering teams. Incidents are documented and tracked to resolution.	Inspected the monitoring software, monitoring alert configurations, and system monitoring procedures to determine whether the System is configured to monitor system capacity and performance 24/7/365.	No exceptions noted.
		Inspected resolution tickets for a selection of system capacity and performance events to determine whether they were documented and tracked to resolution.	No exceptions noted.

Control Objective 5 – Data Backup and Replication

Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up and replicated to an alternate infrastructure securely.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
5.1	A policy exists that establishes backup requirements.	Inspected the Backup Policy to determine whether backup requirements have been established and documented.	No exceptions noted.
5.2	Recurring database backups are performed to ensure the availability of systems.	Inspected the AWS base image configuration and the backup configuration for a selected AWS database, and Azure and GCP vendor backup documentation, to determine whether recurring backups are enabled to ensure availability of the systems.	No exceptions noted.
5.3	Backups to separate facilities, in cloud service data center provider environments, are enabled.	Inspected the base image configuration and the backup configuration for a selected AWS, Azure, and GCP database to determine whether Databricks enabled backups to separate facilities.	No exceptions noted.
		Inspected the Multi-AZ exception approval form to determine that management acknowledged and accepted the risk of disabling Multi-AZ for AWS GovCloud beginning August 14, 2024.	No exceptions noted.
5.4	Database restoration testing is performed at least annually.	Inspected the AWS, Azure, and GCP database backup restoration test results to determine whether database restoration testing was performed annually.	No exceptions noted.

Control Objective 5 – Data Backup and Replication

Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up and replicated to an alternate infrastructure securely.

Control Number	Controls Specified by Databricks, Inc.	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
5.5	Database backups are encrypted.	Inspected the AWS base image configuration and the backup configuration for a selected AWS database to determine whether backups were encrypted and inspected Azure and GCP vendor backup documentation to determine whether backups are configured to be encrypted by default.	No exceptions noted.